LAPORAN TUGAS MANDIRI

Eksplorasi dan Pemahaman Common Vulnerability Scoring System (CVSS) Version 4.0 Calculator

Mata Kuliah: Keamanan Sistem Informasi
Topik: Penilaian Keparahan Kerentanan Menggunakan Standar CVSS v4.0
Alat Pengujian: FIRST CVSS v4.0 Official Calculator (https://www.first.org/cvss/calculator/4.0)

DAFTAR ISI

1. Bagian A: Konsep Dasar CVSS v4.0
2. Bagian B: Eksplorasi Base Metrics (11 Metrik)
3. Bagian C: Threat, Environmental, dan Supplemental Metrics
4. Bagian D: Struktur dan Pembacaan Vector String
5. Bagian E: Hasil dan Pembahasan 4 Simulasi
6. Bagian F: Tabel Perbandingan dan Analisis Pertanyaan Kritis
7. Panduan Langkah Input Kalkulator FIRST (Siap Screenshot)
8. Kesimpulan

Bagian A: Konsep Dasar CVSS v4.0

1. Pengertian, Tujuan, dan Manfaat CVSS

- **Pengertian:** *Common Vulnerability Scoring System* (CVSS) adalah standar industri terbuka (*open standard*) yang dikelola oleh FIRST (*Forum of Incident Response and Security Teams*) untuk mengukur dan mengomunikasikan karakteristik serta tingkat keparahan (*severity*) kerentanan perangkat lunak dan perangkat keras.
- **Tujuan:** Menyediakan metode penilaian yang terstandarisasi, netral vendor, objektif, dan dapat direproduksi (*repeatable*) di seluruh dunia.
- **Manfaat:** Membantu tim keamanan (*security engineers*), pengembang, dan auditor dalam memprioritaskan remediasi kerentanan (*patch management*), mendukung standarisasi basis data global (seperti NVD dan CVE), serta menyelaraskan komunikasi teknis antar organisasi.

2. Perbedaan Vulnerability, Threat, Risk, dan Severity

- **Vulnerability (Kerentanan):** Cacat atau kelemahan logis pada kode, konfigurasi, atau desain sistem yang dapat disalahgunakan (misal: *endpoint* API tanpa validasi otorisasi).
- **Threat (Ancaman):** Aktor eksternal, entitas, atau kejadian potensial yang memiliki kemampuan dan niat untuk mengeksploitasi kerentanan tersebut (misal: penyerang siber, skrip bot otomatis).
- **Severity (Keparahan):** Besaran dampak teknis intrinsik dan kemudahan eksploitasi suatu kerentanan secara independen tanpa memandang konteks lingkungan implementasi (diukur oleh skor dasar CVSS).
- **Risk (Risiko):** Probabilitas terjadinya serangan nyata yang dikalikan dengan dampak finansial atau operasional bisnis aktual terhadap organisasi (**Risk = Threat \times Vulnerability \times Business Impact**). CVSS mengukur *severity*, bukan *risk*.

3. Fungsi Empat Kelompok Metrik CVSS v4.0

1. **Base Metric Group:** Menilai karakteristik intrinsik kerentanan yang konstan lintas waktu dan lingkungan pengguna (vektor akses, kompleksitas, prasyarat, otentikasi, interaksi, dan dampak CIA pada sistem rentan serta sistem turunan).
2. **Threat Metric Group:** Menilai kondisi dinamis eksploitasi di dunia nyata yang berubah seiring waktu (*Exploit Maturity*).
3. **Environmental Metric Group:** Menilai tingkat kepentingan aset dan penyesuaian metrik dasar berdasarkan kontrol keamanan lokal di lingkungan spesifik organisasi.
4. **Supplemental Metric Group:** Menyediakan indikator konteks operasional tambahan tanpa memengaruhi skor numerik akhir.

4. Nomenklatur Skor Resmi CVSS v4.0

Untuk menghindari kerancuan bahwa skor dasar (*Base*) adalah skor risiko akhir, CVSS v4.0 mewajibkan penggunaan label skor: - **CVSS-B:** Penilaian hanya menggunakan *Base Metrics*. - **CVSS-BT:** Penilaian menggabungkan *Base* dan *Threat Metrics*. - **CVSS-BE:** Penilaian menggabungkan *Base* dan *Environmental Metrics*. - **CVSS-BTE:** Penilaian komprehensif menggabungkan *Base*, *Threat*, dan *Environmental Metrics*.

5. Kategori Severity Kualitatif

FIRST memetakan skor numerik 0.0 – 10.0 ke dalam 5 tingkatan keparahan: - **None:** Skor `0.0` (tidak ada dampak teknis langsung). - **Low:** Skor `0.1 – 3.9` (dampak minimal atau eksploitasi membutuhkan kondisi sangat sulit). - **Medium:** Skor `4.0 – 6.9` (dampak moderat, mitigasi dijadwalkan pada rilis reguler). - **High:** Skor `7.0 – 8.9` (ancaman serius terhadap CIA, memerlukan penanganan prioritas). - **Critical:** Skor `9.0 – 10.0` (eksploitasi mudah, dampak fatal, memerlukan perbaikan darurat/*hotfix*).

6. Hubungan Nilai Metrik, Vector String, Skor Numerik, dan Severity

Pilihan Nilai Metrik \longrightarrow Vector String Terstandarisasi \longrightarrow Algoritma Macro-Vectors (Lookup Table) \longrightarrow Skor Numerik (0.0–10.0) \longrightarrow Severity Rating

Setiap pilihan nilai metrik dicatat dalam *vector string*. Algoritma CVSS v4.0 mengelompokkan nilai tersebut ke dalam 6 dimensi *Macro-Vectors (Equivalence Classes)*, mencari skor dasar terkalibrasi pada tabel lookup para pakar, lalu menginterpolasi skor numerik akhir yang kemudian diklasifikasikan ke kategori *Severity*.

Bagian B: Eksplorasi Base Metrics (11 Metrik)

No	Metrik (Singkatan)	Tujuan Penilaian	Pilihan Nilai & Artinya	Contoh Skenario Nyata
1	**Attack Vector (AV)**	Mengukur jarak dan jalur jaringan yang dibutuhkan penyerang untuk mengeksploitasi celah.	**N (Network):** Jarak jauh via internet L3. **A (Adjacent):** Satu jaringan lokal/subnet/Bluetooth. **L (Local):** Akses konsol/terminal/file lokal. **P (Physical):** Kontak fisik dengan perangkat keras.	Endpoint API web klinik yang dapat diakses publik dari browser mana pun (`AV:N`).
2	**Attack Complexity (AC)**	Mengukur keberadaan mekanisme pertahanan bawaan yang harus dipecahkan penyerang.	**L (Low):** Eksploitasi langsung dan deterministik. **H (High):** Harus memecahkan enkripsi, bypass ASLR/DEP, atau rekayasa balik.	Membaca endpoint tanpa enkripsi (`AC:L`) vs memotong sesi TLS terenkripsi (`AC:H`).
3	**Attack Requirements (AT)**	Mengukur ketergantungan pada kondisi eksternal atau konfigurasi di luar kendali penyerang.	**N (None):** Serangan berhasil kapan saja. **P (Present):** Butuh *race condition* spesifik atau manipulasi perantara (MitM).	Eksploitasi SQLi langsung (`AT:N`) vs mengeksploitasi celah yang butuh kondisi *race condition* mikrodetik (`AT:P`).
4	**Privileges Required (PR)**	Mengukur tingkat hak otorisasi yang wajib dimiliki penyerang sebelum menyerang.	**N (None):** Tanpa otentikasi (anonim). **L (Low):** Akun pengguna biasa. **H (High):** Akun administrator/root.	Penyerang internet tanpa login (`PR:N`) vs pasien yang harus login akun portal (`PR:L`).
5	**User Interaction (UI)**	Mengukur keterlibatan pengguna sah dalam keberhasilan serangan.	**N (None):** Tanpa interaksi pengguna lain. **P (Passive):** Korban hanya membuka tautan/email. **A (Active):** Korban harus menekan tombol setuju/menonaktifkan proteksi.	Request API mandiri (`UI:N`) vs serangan XSS di mana korban membuka halaman profil (`UI:P`).
6	**Vuln. System Confid. (VC)**	Mengukur dampak kebocoran kerahasiaan data pada sistem yang langsung memuat bug.	**N (None):** Tidak ada data bocor. **L (Low):** Data terbatas/non-kritis bocor. **H (High):** Seluruh data rahasia/identitas bocor.	Penyerang mengunduh seluruh rekam medis dan NIK pasien dari basis data aplikasi (`VC:H`).
7	**Vuln. System Integrity (VI)**	Mengukur dampak modifikasi data tidak sah pada sistem rentan.	**N (None):** Tidak ada data terubah. **L (Low):** Modifikasi sebagian data kecil. **H (High):** Modifikasi penuh/penghapusan data inti.	Penyerang mengubah diagnosa medis, resep obat, atau menghapus riwayat kunjungan (`VI:H`).
8	**Vuln. System Avail. (VA)**	Mengukur dampak penurunan atau kelumpuhan ketersediaan layanan sistem rentan.	**N (None):** Layanan berjalan normal. **L (Low):** Penurunan performa parsial. **H (High):** Sistem crash/mati total (DoS).	Server web aplikasi klinik down total akibat banjir paket request tak berujung (`VA:H`).
9	**Subsequent Confid. (SC)**	Mengukur kebocoran data lanjutan pada sistem di luar batas sistem rentan.	**N (None):** Sistem lain aman. **L (Low):** Informasi non-kritis bocor. **H (High):** Data rahasia sistem luar bocor penuh.	Dari aplikasi web, penyerang membobol kredensial cloud storage AWS milik rumah sakit (`SC:H`).
10	**Subsequent Integrity (SI)**	Mengukur manipulasi data pada sistem luar yang terhubung secara independen.	**N (None):** Tidak ada dampak luar. **L (Low):** Modifikasi minor pada log luar. **H (High):** Perubahan masif pada sistem rekanan.	Celah web klinik memungkinkan manipulasi hasil uji lab pada server laboratorium independen (`SI:H`).
11	**Subsequent Avail. (SA)**	Mengukur gangguan ketersediaan pada sistem eksternal atau downstream.	**N (None):** Sistem hilir normal. **L (Low):** Gangguan kecil pada sistem luar. **H (High):** Sistem eksternal mati total.	Celah pada klinik menyebabkan server pembayaran gateway eksternal mengalami disrupsi fatal (`SA:H`).

Penekanan Perbedaan Konseptual Krusial

1. **Attack Complexity (AC) vs. Attack Requirements (AT):**
2. **AC** menilai **mekanisme pertahanan bawaan sistem** yang harus ditaklukkan penyerang (keahlian teknis/bypass proteksi).
3. **AT** menilai **kondisi lingkungan eksternal** yang berada di luar kendali penyerang (misal keharusan adanya penyerang di tengah jaringan / MitM, konfigurasi langka, atau *race condition*).
4. **Privileges Required (PR) vs. User Interaction (UI):**
5. **PR** berfokus pada **hak otorisasi penyerang** sebelum eksploitasi dimulai.
6. **UI** berfokus pada **keterlibatan pengguna korban** untuk memicu muatan eksploitasi.
7. **Vulnerable System (VC/VI/VA) vs. Subsequent System (SC/SI/SA):**
8. *Vulnerable System* adalah komponen perangkat lunak yang memuat kode/cacat keamanan secara fisik.
9. *Subsequent System* adalah entitas komputasi lain yang terpisah secara otorisasi (OS *host*, basis data eksternal, atau sistem mitra independen).

Bagian C: Threat, Environmental, dan Supplemental Metrics

1. Threat Metrics: Exploit Maturity (E)

Mengukur ketersediaan teknik/alat eksploitasi di dunia nyata: - **Not Defined (X):** Nilai default jika metrik ancaman tidak dinilai. - **Unreported (U):** Belum ada eksploit publik yang diketahui atau hanya solusi teoritis. - **Proof-of-Concept (P):** Kode PoC atau demonstrasi serangan tersedia di publik (misal di GitHub), tetapi belum digunakan luas. - **Attacked (A):** Eksploitasi aktif telah terjadi di alam liar atau terdapat alat serangan otomatis (*weaponized exploit kit*) yang beredar bebas.

2. Environmental Metrics

- **Modified Base Metrics (MAV, MAC, MAT, MPR, MUI, MVC, MVI, MVA, MSC, MSI, MSA):** Memungkinkan analis mengganti nilai dasar jika organisasi telah memasang kontrol kompensasi (misal memindahkan endpoint web publik ke jaringan intranet internal, sehingga **MAV:A**).
- **Security Requirements (CR, IR, AR):** Mengukur tingkat kepentingan aset terhadap prinsip Kerahasiaan (**CR**), Keutuhan (**IR**), dan Ketersediaan (**AR**) bagi kelangsungan bisnis (*Low, Medium, High*).

3. Supplemental Metrics (Konteks Operasional)

Metrik kualitatif opsional yang memberi wawasan mendalam: - **Safety (S):** Dampak terhadap keselamatan fisik manusia (*Negligible [N] / Present [P]*). - **Automatable (AU):** Kemampuan worm/botnet mengotomatisasi serangan awal (*No [N] / Yes [Y]*). - **Recovery (R):** Pemulihan sistem (*Automatic [A], User [U], Irrecoverable [I]*). - **Value Density (V):** Konsentrasi nilai sumber daya yang diekspos (*Diffuse [D] / Concentrated [C]*). - **Vulnerability Response Effort (RE):** Biaya dan kesulitan membuat mitigasi (*Low [L], Medium [M], High [H]*). - **Provider Urgency (U):** Rekomendasi urgensi dari vendor (*Clear, Green, Amber, Red*).

Mengapa Supplemental Metrics tidak mengubah skor numerik?
Agar skor keparahan teknis universal (**CVSS-B**) tetap konsisten dan dapat dibandingkan antar organisasi di seluruh dunia tanpa terdistorsi oleh faktor lokal subjektif, sembari tetap memberikan metadata kontekstual bernilai tinggi bagi analis insiden internal.

Bagian D: Struktur dan Pembacaan Vector String

1. **Awalan `CVSS:4.0`:** Penanda skema versi standar yang digunakan (memastikan mesin parser mengenali algoritma kalkulasi versi 4.0).
2. **Karakter `/` dan `:`:** Karakter slash (`/`) memisahkan antar metrik, sedangkan titik dua (`:`) memisahkan kode singkatan metrik dengan nilai pilihannya.
3. **Hubungan Singkatan dan Nilai:** Format ringkas pasangan **Metrik:Nilai**, contohnya `AV:N` bermakna *Attack Vector* = *Network*.
4. **Pembentukan Vector String:** Dibentuk dengan menggabungkan 11 metrik dasar wajib, ditambah metrik Threat, Environmental, atau Supplemental jika didefinisikan.
5. **Reproduksibilitas:** Vector string bersifat deterministik universal. Siapa pun yang memasukkan string yang sama ke kalkulator CVSS v4.0 di mana pun akan menghasilkan skor dan tingkat keparahan yang persis sama.

Contoh Vector String Base CVSS v4.0 dan Maknanya

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

- `CVSS:4.0` : Versi standar CVSS v4.0.
- `AV:N` : Attack Vector = Network (dapat diserang dari internet publik).
- `AC:L` : Attack Complexity = Low (tidak ada mekanisme pertahanan yang menghambat).
- `AT:N` : Attack Requirements = None (tidak butuh kondisi lingkungan khusus).
- `PR:N` : Privileges Required = None (penyerang tidak memerlukan akun/login).
- `UI:N` : User Interaction = None (tidak memerlukan interaksi korban).
- `VC:H` : Vulnerable System Confidentiality = High (seluruh data rahasia bocor).
- `VI:N` : Vulnerable System Integrity = None (tidak ada manipulasi data pada sistem klinik).
- `VA:N` : Vulnerable System Availability = None (sistem klinik tidak lumpuh).
- `SC:N` : Subsequent System Confidentiality = None (tidak ada kebocoran pada sistem luar).
- `SI:N` : Subsequent System Integrity = None (tidak ada perubahan data sistem luar).
- `SA:N` : Subsequent System Availability = None (sistem luar tetap beroperasi normal).

Bagian E: Hasil dan Pembahasan 4 Simulasi

Simulasi 1: Kebocoran Data Pasien

- **Skenario:** Endpoint aplikasi klinik terbuka ke internet tanpa login, mengekspos seluruh data identitas dan riwayat kunjungan pasien. Tidak ada perubahan data atau disrupsi layanan.
- **Base Metrics:** `AV:N / AC:L / AT:N / PR:N / UI:N / VC:H / VI:N / VA:N / SC:N / SI:N / SA:N`
- **Vector String:** `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`
- **Skor CVSS v4.0: 8.7** | **Severity: HIGH**
- **Justifikasi:** Penyerang jarak jauh tanpa otentikasi dapat mencuri seluruh data sensitif pasien (**VC:H**). Ketiadaan dampak integritas dan ketersediaan menempatkan keparahan pada batas atas level *High*.

Simulasi 2: Manipulasi Data Pasien

- **Skenario:** Melanjutkan Simulasi 1, namun penyerang kini juga memiliki kemampuan memodifikasi seluruh data rekam medis pasien secara tidak sah.
- **Metrik yang Berubah: VI** berubah dari **None (N)** menjadi **High (H)**.
- **Vector String:** `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`
- **Skor CVSS v4.0: 9.3** | **Severity: CRITICAL**
- **Justifikasi:** Kombinasi hilangnya kerahasiaan total (**VC:H**) dan integritas total (**VI:H**) tanpa proteksi otentikasi (**PR:N**) mendorong skor melompat ke kategori *Critical*. Pasien dapat mengalami bahaya salah diagnosa atau resep obat palsu.

Simulasi 3: Pengaruh Autentikasi

- **Skenario:** Mengembalikan kondisi Simulasi 1, namun celah kebocoran data hanya dapat diakses oleh pengguna yang telah login menggunakan akun biasa.
- **Metrik yang Berubah: PR** berubah dari **None (N)** menjadi **Low (L)** (sementara **VI** kembali bernilai **N**).
- **Vector String:** `CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`
- **Skor CVSS v4.0: 7.1** | **Severity: HIGH**
- **Justifikasi:** Keharusan memiliki akun sah membatasi vektor ancaman hanya pada pengguna internal terdaftar. Hambatan otentikasi ini menurunkan skor dari 8.7 menjadi 7.1 (-1.6 poin).

Simulasi 4: Dampak pada Sistem Lain (Subsequent System)

- **Skenario:** Kerentanan pada aplikasi klinik memungkinkan perubahan data signifikan pada aplikasi klinik serta merembet mengubah data pada sistem laboratorium independen yang terhubung.
- **Identifikasi Dampak Sistem:**
- *Vulnerable System:* Integritas data klinik rusak parah (**VI:H**).
- *Subsequent System:* Integritas data laboratorium independen terkompromi (**SI:H**).
- **Base Metrics (Kondisi Modifikasi Lintas Sistem):**
- **Variasi 4A (Manipulasi Murni):** `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:N/SC:N/SI:H/SA:N`
  \rightarrow Skor: 9.2 | **Severity: CRITICAL**
- **Variasi 4B (Kebocoran + Manipulasi Lintas Sistem):** `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:H/SA:N`
  \rightarrow Skor: 9.9 | **Severity: CRITICAL**
- **Justifikasi:** Adanya eskalasi dampak lintas batas otorisasi menuju sistem downstream laboratorium (**SI:H**) membuktikan fitur pemisahan dampak CVSS v4.0, mengangkat risiko kegagalan sistematis antar-lembaga ke skor mendekati sempurna (9.2 – 9.9).

Bagian F: Tabel Perbandingan dan Analisis Pertanyaan Kritis

Tabel Perbandingan Hasil Simulasi

Simulasi	Metrik yang Berubah	Vector String Lengkap	Skor CVSS	Severity	Penjelasan Perubahan Dampak & Risiko
1	*(Kondisi Dasar)*	`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`	**8.7**	**HIGH**	Kebocoran data rekam medis pasien secara masif dari internet tanpa autentikasi.
2	**VI: N \rightarrow \mathbf{H}**	`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N`	**9.3**	**CRITICAL**	Skor naik **+0.6** ke *Critical* karena integritas data juga runtuh (data bisa dipalsukan).
3	**PR: N \rightarrow \mathbf{L}**	`CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`	**7.1**	**HIGH**	Skor turun **-1.6** karena penyerang harus terdaftar dan memiliki kredensial sah.
4	**VI: \mathbf{H}, SI: \mathbf{H}**	`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:N/SC:N/SI:H/SA:N`	**9.2**	**CRITICAL**	Dampak merembet ke sistem lab luar (**SI:H**), memicu risiko integritas multi-sistem.

Analisis Pertanyaan Kritis

1. **Mengapa perubahan satu metrik dapat memengaruhi skor akhir?**
   Karena algoritma CVSS v4.0 menggunakan *Equivalence Classes (Macro-Vectors)*. Perubahan satu metrik (misal dari **PR:N** ke **PR:L**) memindahkan posisi vektor ke kelas ekuivalen yang memiliki bobot kemudahan eksploitasi lebih rendah pada tabel lookup terkalibrasi.
2. **Apakah dua vector string berbeda selalu menghasilkan skor berbeda?**
   Tidak. Konsep *Equivalence Classes* pada CVSS v4.0 mengelompokkan kombinasi metrik yang memiliki tingkat keparahan setara ke dalam macro-vector yang sama. Sebagai contoh, pertukaran dampak antara sistem rentan dan sistem turunan pada konfigurasi tertentu dapat menghasilkan skor numerik yang identik.
3. **Mengapa severity tidak boleh ditentukan hanya berdasarkan nama kerentanan?**
   Karena keparahan teknis nyata bergantung mutlak pada **konteks arsitektur dan eksposur**. Kerentanan SQL Injection yang berada pada antarmuka admin lokal intranet di balik otentikasi dua faktor memiliki tingkat keparahan riil yang jauh lebih rendah dibandingkan SQL Injection pada halaman login publik tanpa otentikasi.
4. **Mengapa hasil CVSS tidak dapat langsung dianggap sebagai ukuran keseluruhan risiko organisasi?**
   Karena CVSS mengukur **keparahan teknis intrinsik (*severity*)**, bukan probabilitas atau dampak bisnis nyata (*risk*). Celah dengan skor 9.8 pada server pengujian yang terisolasi tanpa data sensitif memiliki risiko bisnis yang jauh lebih kecil daripada celah ber-skor 6.5 yang aktif dieksploitasi penyerang pada server basis data transaksi utama.
5. **Mengapa penilaian metrik harus didasarkan pada bukti teknis?**
   Untuk menjaga objektivitas, mencegah over-scoring (inflasi keparahan) atau under-scoring, serta memastikan hasil penilaian dapat diaudit dan direproduksi (*reproducible*) secara konsisten oleh analis keamanan lain.

Panduan Langkah Input Kalkulator FIRST (Siap Screenshot)

Buka tautan resmi https://www.first.org/cvss/calculator/4.0. Mahasiswa dapat mengklik tombol radio sesuai tabel panduan di bawah ini, atau **langsung membuka URL dengan hash vector** agar kalkulator terisi otomatis secara presisi:

PANDUAN PEMILIHAN TOMBOL RADIO PADA KALKULATOR FIRST CVSS v4.0

Simulasi	AV	AC	AT	PR	UI	VC	VI	VA	SC	SI	SA	Skor Akhir	Severity	Tautan Langsung Terisi Otomatis
Sim. 1	N	L	N	N	N	H	N	N	N	N	N	8.7	HIGH	first.org/cvss/calculator/4.0#...Sim1
Sim. 2	N	L	N	N	N	H	H	N	N	N	N	9.3	CRITICAL	first.org/cvss/calculator/4.0#...Sim2
Sim. 3	N	L	N	L	N	H	N	N	N	N	N	7.1	HIGH	first.org/cvss/calculator/4.0#...Sim3
Sim. 4	N	L	N	N	N	N	H	N	N	H	N	9.2	CRITICAL	first.org/cvss/calculator/4.0#...Sim4

Tautan Langsung ke Kalkulator FIRST Resmi (Klik untuk Membuka & Screenshot):

1. **Simulasi 1 (Kebocoran):**
   https://www.first.org/cvss/calculator/4.0#CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
2. **Simulasi 2 (Manipulasi):**
   https://www.first.org/cvss/calculator/4.0#CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N
3. **Simulasi 3 (Autentikasi PR:L):**
   https://www.first.org/cvss/calculator/4.0#CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
4. **Simulasi 4 (Dampak Sistem Lain):**
   https://www.first.org/cvss/calculator/4.0#CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:N/SC:N/SI:H/SA:N

(Tips Screenshot: Saat membuka tautan di atas, halaman kalkulator FIRST akan otomatis memilih seluruh tombol radio yang sesuai, menampilkan badge skor numerik besar di sebelah kanan atas, menampilkan badge tingkat keparahan kualitatif, serta menampilkan vector string resmi. Ambil tangkapan layar pada area tersebut).

Kesimpulan

1. **CVSS v4.0 Memberikan Penilaian Lebih Akurat:** Pemisahan dampak antara sistem rentan (*Vulnerable System*) dan sistem turunan (*Subsequent System*) serta penambahan metrik *Attack Requirements* menghasilkan penilaian yang jauh lebih presisi dibandingkan versi pendahulunya.
2. **Sensitivitas Terhadap Konteks Otorisasi:** Simulasi membuktikan bahwa penambahan kontrol otentikasi (**PR:N \rightarrow PR:L**) mampu menurunkan skor keparahan secara signifikan dari 8.7 menjadi 7.1.
3. **Pembedaan Ranah Severity vs. Risk:** Skor CVSS adalah cerminan keparahan teknis murni dan harus diintegrasikan dengan konteks ancaman aktif (*Threat*) dan lingkungan lokal (*Environmental*) sebelum dijadikan keputusan akhir manajemen risiko organisasi.